SIMATS ENGINEERING

ASSESSMENT TOOL 3 – SCENARIO-BASED ASSESSMENT

COURSE NAME: Ethical Hacking
COURSE CODE: ITA1410

STUDENT NAME: K. Sri Lasya

REGISTER NUMBER: 192472216

QUESTION 1: FOOTPRINTING TOOLS – CONDUCTING COMPETITIVE INTELLIGENCE

1.1 Introduction

Footprinting is an information-gathering process used in ethical hacking to collect details about an organization, its domain names, network infrastructure, employees, and technologies. It is generally performed during the initial phase of a security assessment to understand the target's digital presence and identify potential security risks.

Competitive intelligence involves collecting and analyzing publicly available information about an organization to understand its online presence, technology choices, business activities, and potential security exposure. In cybersecurity, this information can help security professionals identify publicly exposed assets and recommend appropriate protective measures.

Footprinting can be classified into two main types: passive footprinting and active footprinting.

Passive footprinting collects information from existing public sources without directly interacting with the target organization's servers. Examples include domain registration databases, search engines, public company websites, certificate transparency records, and technology profiling services.

Active footprinting involves directly interacting with the target's infrastructure, such as by scanning ports or sending probes to servers. Although active techniques can provide additional technical information, they are outside the scope of the given scenario.

In this scenario, a cybersecurity consultant has been assigned to conduct a passive security assessment for ABC Technologies. The consultant must identify the company's domain registration details, employee email addresses, technology stack, and publicly exposed subdomains without directly interacting with the company's servers.

The appropriate approach is to combine several passive footprinting tools, verify information across reliable sources, and document findings with their potential security implications.

1.2 Objectives

The main objectives of this assessment are:

1. To identify the domain registration details of ABC Technologies.
2. To discover publicly available employee email addresses.
3. To identify technologies used by the organization's public-facing websites.
4. To discover publicly documented or indexed subdomains.
5. To understand how passive footprinting tools support competitive intelligence.
6. To identify security risks associated with publicly exposed information.
7. To recommend measures that reduce unnecessary information exposure.

1.3 Understanding the Scenario

The consultant must gather information without directly interacting with ABC Technologies' servers.

This requirement is important because a passive assessment should minimize direct contact with the target infrastructure. Instead of initiating port scans or sending specially crafted requests to the organization's servers, the consultant should rely on existing public records and third-party information sources.



Figure 1.1: WHOIS output showing domain registration details.

The four information categories are described below.

Information Required	Suitable Tool or Source	Purpose
Domain registration details	WHOIS and ICANN Lookup	Identify registration information and domain metadata
Employee email addresses	Search engines and Hunter.io	Discover publicly listed organizational email addresses
Technology stack	Wappalyzer and BuiltWith	Identify technologies used by public websites
Publicly exposed subdomains	Certificate Transparency logs, passive DNS sources, and search engines	Discover additional public hostnames

The availability of information varies depending on the organization's privacy settings, domain registrar, website configuration, and the coverage of the selected tools.

1.4 Domain Registration Details Using WHOIS

1.4.1 Overview of WHOIS

WHOIS is a query service historically used to retrieve domain registration information. Depending on the domain registry and privacy settings, the information may include the registrar, registration dates, domain status, and name servers.

Some registration data may be redacted or replaced with privacy-protection details. For many generic top-level domains, ICANN Lookup provides a convenient way to inspect available registration data.

1.4.2 Information That Can Be Collected

The consultant can attempt to identify the following details for ABC Technologies:

- Registered domain name.
- Domain registrar.
- Domain creation date.
- Domain expiration date, when available.
- Last updated date.
- Domain status codes.

- Authoritative name servers.
- Registrant organization or contact information, if publicly available.

1.4.3 Application of the Tool

The consultant should first identify the company's official domain using reliable public sources, such as the company's public website or verified business profiles.

The consultant can then inspect the domain using WHOIS or ICANN Lookup.

Example command:

whois example.com

Here, example.com is a placeholder and should be replaced with the verified domain being assessed. This query uses a public domain as an example; it does not represent a finding about ABC Technologies.

The output should be reviewed for the available registration information, registrar details, domain status, and name servers.

If the WHOIS command is unavailable, an online registration lookup service can be used instead.

1.4.4 Security Significance

Domain registration information can help a security analyst understand the organization's digital identity and identify domains that require further administrative review.

For example, an unexpected change in domain registration details or name servers may warrant investigation.

Registration dates may also help analysts understand the age of a domain. However, a newly registered domain is not automatically malicious, and a long-established domain is not automatically secure.

1.4.5 Limitations

WHOIS does not necessarily disclose the real identity or contact information of the domain owner. Privacy-protection services and data protection requirements may restrict the information available.

The information also does not directly prove that a domain is vulnerable. It provides contextual information that should be combined with other authorized assessment findings.

1.5 Employee Email Discovery Using Search Engines and Hunter.io

1.5.1 Importance of Email Footprinting

Email addresses are important organizational identifiers. They are used for communication, account registration, password recovery, and access to business applications.

Publicly listed email addresses may help an organization understand which contact details are visible to external users.

During a passive security assessment, discovering publicly available email addresses can also help identify unnecessary exposure of employee information.

1.5.2 Search Engine Techniques

Search engines can identify email addresses published on company websites, professional profiles, event pages, public documents, and other indexed sources.

The consultant can use targeted searches to locate publicly indexed organizational contact information.

Illustrative search queries include:

site:example.com email

site:example.com "@example.com"

These examples use a placeholder domain. The actual assessment should use ABC Technologies' verified public domain.

The consultant should record the source URL and the context in which each email address was published.

1.5.3 Hunter.io

Hunter.io is an online service designed to help discover publicly associated professional email addresses and email patterns for domains.

Depending on the available features and service limits, it may provide information such as:

- Publicly associated professional email addresses.
- Common organizational email patterns.
- Source references for discovered addresses, when available.
- Confidence indicators for some results.

For example, a company might use an email pattern such as firstname.lastname@example.com. This is only an illustrative pattern and must not be assumed to apply to ABC Technologies without supporting evidence.

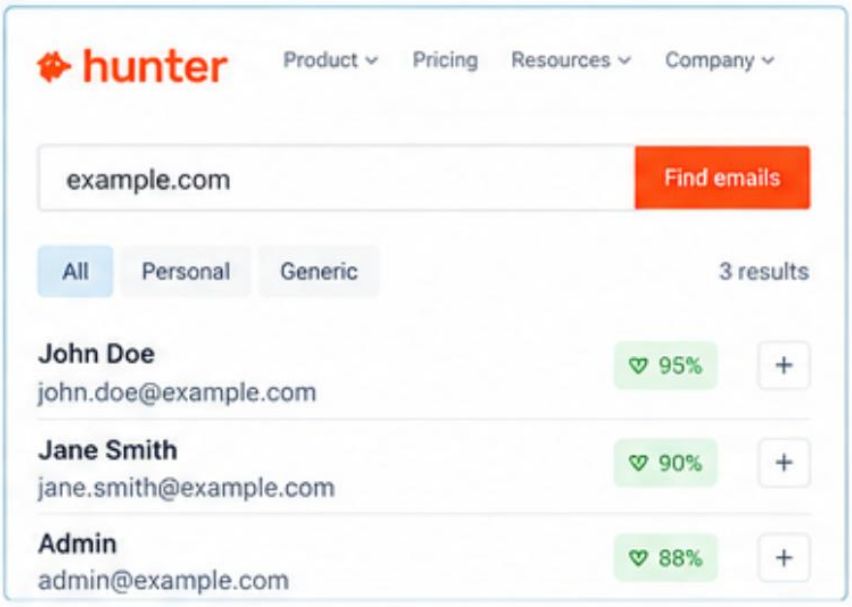


Figure 1.2: Hunter.io output showing publicly available employee email addresses.

1.5.4 Application in the Scenario

The consultant should:

1. Confirm the organization's official domain.
2. Search publicly indexed pages for company contact details.
3. Use a suitable email-discovery service to identify publicly associated addresses.
4. Record the source and date of each finding.
5. Distinguish verified published addresses from inferred email patterns.
6. Avoid sending test emails or attempting to authenticate to employee accounts.

1.5.5 Security Risks Associated with Exposed Email Addresses

Publicly exposed email addresses may increase the risk of targeted phishing, spam, impersonation, and fraudulent business communication.

Attackers may use publicly available names and job titles to create convincing messages that appear to come from managers, suppliers, or IT support personnel.

However, the public availability of an email address does not mean that the account is compromised or that publishing the address is inherently insecure. The risk depends on the context and the organization's protective controls.

1.5.6 Recommended Security Measures

- Publish role-based contact addresses for general inquiries wherever practical.
- Avoid unnecessarily publishing sensitive employee contact information.
- Train employees to identify suspicious email requests.
- Implement effective email filtering and authentication.
- Use SPF, DKIM, and DMARC to help protect the organization's email domain against spoofing.
- Enforce multi-factor authentication for important accounts.
- Establish a clear process for reporting suspicious emails.

1.6 Technology Stack Identification Using Wappalyzer and BuiltWith

1.6.1 Meaning of Technology Stack

A technology stack is the collection of software, frameworks, programming languages, platforms, and services used to build and operate a website or application.

A website may use a content management system, JavaScript frameworks, analytics tools, web servers, cloud services, and other technologies.

Understanding the technology stack helps security professionals identify the software components that require maintenance and security updates.

1.6.2 Wappalyzer

Wappalyzer is a technology-profiling tool that can identify technologies associated with websites using publicly observable indicators.

Depending on the website and available detection methods, it may identify:

- Content management systems.
- JavaScript frameworks.
- Analytics platforms.
- E-commerce platforms.
- Advertising and tracking technologies.
- Some web infrastructure technologies.

A browser extension or supported lookup feature can help inspect a public website's technology profile.

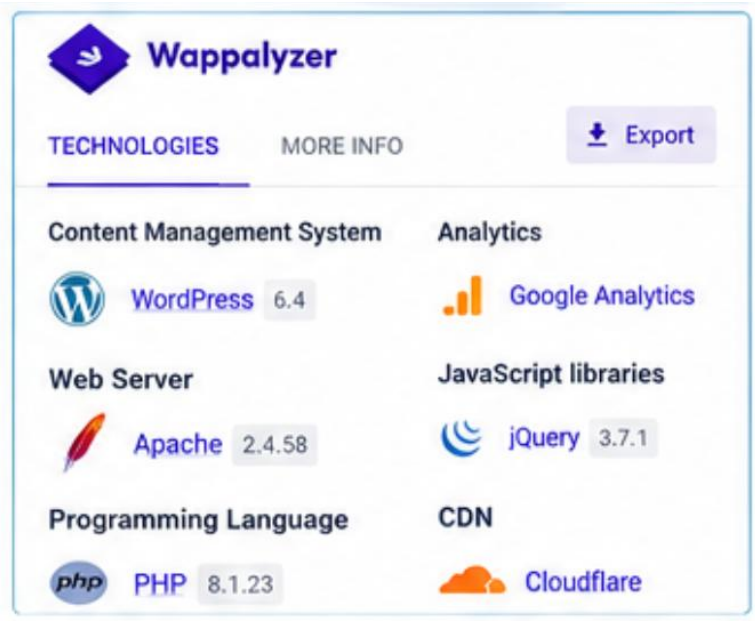


Figure 1.3: Wappalyzer output showing website technology stack.

1.6.3 BuiltWith

BuiltWith is a technology information service that provides profiles of technologies used by websites.

It can help an analyst understand a site's technology choices and identify publicly observable technology trends.

Wappalyzer and BuiltWith may produce different results because their detection methods, data sources, and update schedules differ.

1.6.4 Application in the Scenario

The consultant should identify the official public website of ABC Technologies and inspect its publicly observable technology profile using Wappalyzer or BuiltWith.

The findings should be recorded in a table.

Technology Category	**Example of Information to Record**	**Security Relevance**
Content management system	Detected CMS, if any	Check support status and security updates
JavaScript framework	Detected client-side framework	Review dependencies and update status

Analytics tools	Publicly detected analytics service	Assess privacy and third-party dependencies
E-commerce platform	Platform detected, if applicable	Review payment and application security
Hosting or CDN indicators	Publicly observable service indicators	Understand dependencies and service architecture

These are categories to investigate, not confirmed findings about ABC Technologies.

1.6.5 Security Significance

Technology identification helps an organization maintain an inventory of externally observable technologies.

If a technology is identified as outdated or unsupported, the security team can investigate whether the organization actually uses the affected version and whether applicable vulnerabilities exist.

Attackers may also use technology information to select relevant attack methods. Therefore, organizations should maintain supported software and avoid unnecessary information disclosure.

1.6.6 Limitations

Technology-profiling tools rely on observable indicators and may not detect every component.

Some technologies may be hidden by reverse proxies, content delivery networks, custom configurations, or security controls. A detected technology may also be a third-party service rather than a component managed directly by the organization.

A technology profile should therefore be treated as an initial indication, not a complete software inventory or proof of a vulnerability.

1.7 Public Subdomain Discovery Using Certificate Transparency and Passive Sources

1.7.1 Meaning of a Subdomain

A subdomain is a name that exists beneath a parent domain.

For example, mail.example.com and portal.example.com are illustrative subdomains of example.com.

Organizations may use subdomains for websites, employee portals, APIs, testing environments, documentation, and other services.

1.7.2 Importance of Subdomain Discovery

Subdomain discovery helps organizations identify their publicly visible digital assets.

An overlooked subdomain may point to an outdated application, a forgotten development environment, or a third-party service that requires administrative review.

However, a discovered hostname does not automatically indicate that a service is reachable or vulnerable.

1.7.3 Certificate Transparency Logs

Certificate Transparency (CT) is a system that records information about publicly trusted TLS certificates.

CT logs can contain domain names associated with certificates, including names that may not appear prominently on the organization's main website.

A passive search through a certificate transparency service, such as a public CT log viewer, may reveal previously issued certificate names.

1.7.4 Passive DNS Sources

Passive DNS services collect historical DNS observations from their data sources. Depending on the provider, these services may reveal hostnames that have previously resolved to particular records or addresses.

Passive DNS can help identify historical public naming information without requiring the consultant to scan the organization's servers.

Coverage and historical depth differ across providers.

1.7.5 Search Engine Indexing

Search engines may index public pages associated with subdomains. Searching for the organization's verified domain can help identify additional hostnames and services.

Search results should be checked against reliable sources to avoid false positives and unrelated domains.

1.7.6 Application in the Scenario

The consultant should:

1. Verify the parent domain.
2. Search public CT logs for associated certificate names.
3. Review suitable passive DNS sources.
4. Use search engines to identify publicly indexed subdomains.
5. Compare the discovered hostnames against the organization's publicly documented services.

6. Record the source and confidence level for each hostname.
7. Recommend that ABC Technologies verify whether each discovered asset is required and properly managed.

1.7.7 Security Risks Associated with Publicly Exposed Subdomains

Forgotten assets: Old subdomains may point to systems that are no longer actively maintained.

Outdated applications: Publicly documented subdomains may reveal software that requires a patch review.

Development environment exposure: A hostname may indicate a testing or staging service that warrants access-control verification.

Third-party dependencies: A subdomain may point to a hosted service whose configuration or ownership requires review.

Information disclosure: Hostnames may reveal internal naming conventions or the purpose of particular systems.

These are potential risks to investigate, not proof that the discovered hostnames contain vulnerabilities.

1.8 How the Tools Support Competitive Intelligence

Competitive intelligence in this context means analyzing publicly available information to understand the organization's digital presence and potential security exposure.

Tool	Information Collected	Contribution to Analysis
WHOIS or ICANN Lookup	Registration metadata	Helps verify domain ownership context and registration status
Search engines	Public pages and contact information	Identifies published email addresses and indexed assets
Hunter.io	Publicly associated professional email information	Helps understand publicly visible email patterns
Wappalyzer	Observable website technologies	Helps identify technologies requiring security review
BuiltWith	Technology profile information	Provides additional context about a website's technology choices

Certificate Transparency services	Names appearing in public certificates	Helps discover publicly documented hostnames
Passive DNS services	Historical DNS observations	Helps identify previously observed public subdomains

Combining these tools provides a more comprehensive picture than relying on one source.

For example, certificate records may reveal a hostname that is not linked from the main website. A technology-profiling service may identify the platform used by the website, while registration data may provide additional domain context.

The analyst should verify important findings across multiple sources and clearly distinguish confirmed observations from assumptions.

1.9 Documentation of Findings

The consultant should prepare a structured assessment report containing the following fields:

Field	**Description**
Finding ID	Unique identifier for the observation
Information category	Domain, email, technology, or subdomain
Observed value	The information actually found
Source	Tool or public record used
Observation date	Date the information was collected
Confidence	High, medium, or low, with justification
Security significance	Why the observation matters
Recommended action	Appropriate verification or remediation

Since the scenario does not provide the actual domain name of ABC Technologies, no specific registration records, employee addresses, technology stack, or subdomains can be confirmed from the scenario alone.

A real assessment should populate this table with verified observations rather than inventing findings.

1.10 Ethical and Legal Considerations

Passive footprinting should be performed within the agreed assessment scope and in accordance with applicable law and organizational policies.

The consultant should:

- Use publicly available information for the authorized assessment.
- Avoid attempting to access private accounts or restricted systems.
- Avoid collecting unnecessary personal information.
- Store assessment findings securely.
- Protect employee email addresses and other sensitive information.
- Avoid making unsupported claims about vulnerabilities.
- Report security findings only to authorized recipients.

Although passive collection avoids direct interaction with target servers, the consultant must still consider privacy, data protection, contractual requirements, and the intended use of the information.

1.11 Recommended Security Measures for ABC Technologies

ABC Technologies should periodically review its public digital footprint.

The organization should maintain an inventory of domains and subdomains, verify ownership of externally hosted assets, remove obsolete DNS records, and ensure that public-facing applications receive regular security updates.

Employee contact information should be published only where there is a legitimate business need. The organization should also implement strong email security controls and provide regular phishing awareness training.

Public websites should be reviewed for unnecessary technology disclosures, outdated dependencies, and inappropriate information exposure.

A documented external asset management process can help identify forgotten systems and ensure that appropriate teams remain responsible for maintaining them.

1.12 Conclusion

Passive footprinting is an important part of ethical hacking because it helps security professionals understand an organization's publicly visible digital presence without directly interacting with its servers.

For ABC Technologies, WHOIS or ICANN Lookup can provide domain registration information, search engines and Hunter.io can help identify publicly available email addresses, Wappalyzer and

BuiltWith can provide technology-profile information, and certificate transparency logs or passive DNS sources can help discover public subdomains.

These tools support competitive intelligence by revealing information about domain ownership context, employee contact exposure, technology choices, and public-facing assets.

However, results must be verified because public information sources may be incomplete or outdated. By maintaining an accurate asset inventory, protecting employee information, updating software, and reviewing public exposure regularly, ABC Technologies can reduce unnecessary information disclosure and improve its security posture.

QUESTION 2: DNS ZONE TRANSFERS

2.1 Introduction

The Domain Name System (DNS) is a fundamental part of network communication. It translates domain names into IP addresses and provides information about services such as websites, mail servers, and other network resources.

Organizations depend on DNS for reliable access to their online services. DNS servers must therefore be configured correctly to ensure that records are available to authorized systems while preventing unnecessary disclosure or unauthorized modification.

A DNS zone transfer is a process used to copy DNS zone data between authoritative DNS servers. It is commonly used to synchronize primary and secondary DNS servers.

During an authorized penetration test, a security analyst suspects that the target organization's DNS server may permit unauthorized zone transfers. The analyst must use an appropriate DNS tool to verify the configuration and assess the implications of any exposed records.

The dig command is suitable for this task because it allows security professionals to query DNS servers and test zone-transfer behavior.

2.2 Objectives

The objectives of this assessment are:

1. To understand DNS zone transfers and their purpose.
2. To explain the role of the dig utility.
3. To describe how an authorized analyst can test AXFR access.
4. To interpret successful and unsuccessful zone-transfer responses.

5. To explain how exposed records may assist reconnaissance.
6. To recommend security measures that prevent unauthorized transfers.
7. To describe verification and reporting procedures.

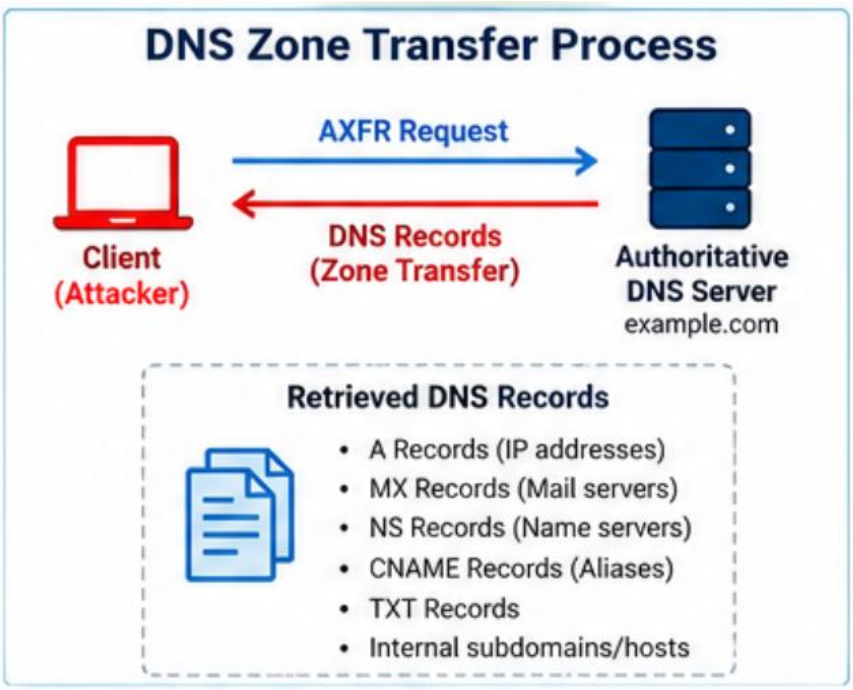


Figure 2.2: DNS zone transfer process.

2.3 Understanding DNS Zones

A DNS zone is a portion of the DNS namespace managed by an authoritative DNS configuration.

A zone contains records that provide information about domain names, IP addresses, mail servers, aliases, and other services.

For example, a company may maintain DNS records for its main website, mail service, and other public-facing applications.

DNS zones may also contain records that are intended for internal use. If these records are exposed unnecessarily, they may reveal information about the organization's network.

2.3.1 Primary DNS Server

A primary DNS server holds the authoritative zone data used as the source for updates and transfers in a conventional primary-secondary arrangement.

2.3.2 Secondary DNS Server

A secondary DNS server maintains a copy of the zone. It obtains zone data from an authorized source and provides redundancy and availability.

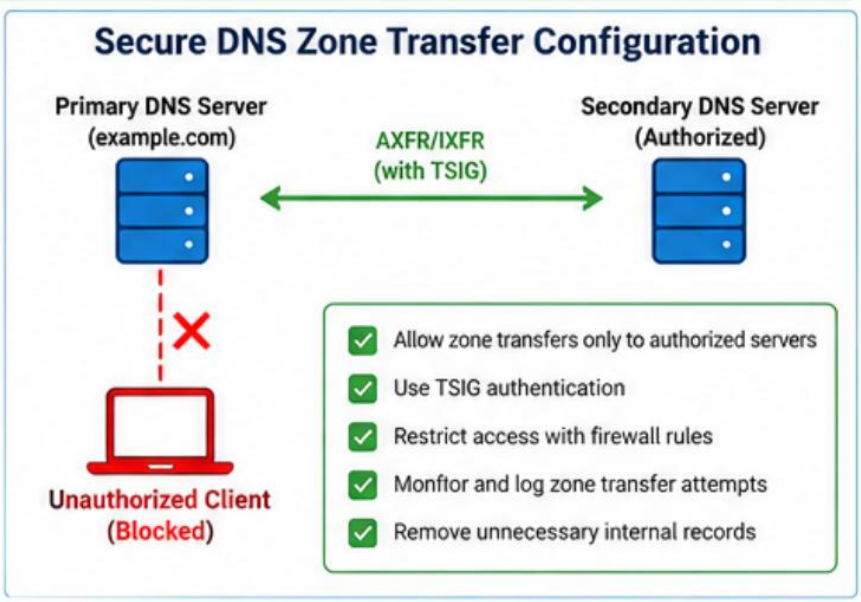


Figure 2.3: Secure DNS zone transfer configuration with best practices.

2.3.3 Importance of DNS Synchronization

Zone transfers help keep multiple authoritative servers consistent.

Without correct synchronization, different servers might provide outdated or inconsistent records, affecting the availability and reliability of network services.

However, zone transfers must be restricted to approved systems because they can expose the complete contents of a zone.

2.4 Types of DNS Zone Transfer

2.4.1 AXFR – Full Zone Transfer

AXFR is used to request a full transfer of DNS zone data.

An authorized secondary server may use AXFR to obtain the records required to maintain its copy of the zone.

If an unauthorized client can perform the same operation, the complete zone may be disclosed.

2.4.2 IXFR – Incremental Zone Transfer

IXFR is designed to transfer changes to a zone rather than requiring the complete zone to be retransmitted in every situation.

It can improve efficiency when only some records have changed.

Both full and incremental transfers should be limited to authorized systems according to the DNS server's capabilities and configuration.

2.5 Overview of the Dig Tool

dig, or Domain Information Groper, is a command-line utility used to query DNS servers and examine their responses.

It is commonly used by administrators and security analysts to troubleshoot DNS configuration, inspect DNS records, and validate authoritative server behavior.

2.5.1 Main Uses

- Query A and AAAA records.
- Inspect MX and NS records.
- Review TXT and SOA records.
- Query a particular DNS server.
- Examine DNS response codes.
- Test zone-transfer permissions during an authorized assessment.
- Verify DNS configuration after remediation.

2.5.2 Advantages

The dig utility provides detailed DNS responses and is available on many Unix-like systems. It can also be installed on other operating systems.

It helps analysts distinguish between ordinary DNS queries and zone-transfer requests and provides information that can support security analysis.

2.6 Testing Zone Transfer Permissions

The analyst should first establish the authorized scope of the penetration test and identify the target domain and its authoritative name servers.

The following command illustrates an AXFR request:

dig AXFR example.com @ns1.example.com

In this example:

- dig invokes the DNS query utility.
- AXFR requests a full zone transfer.

- example.com represents the domain being tested.
- @ns1.example.com identifies the DNS server receiving the request.

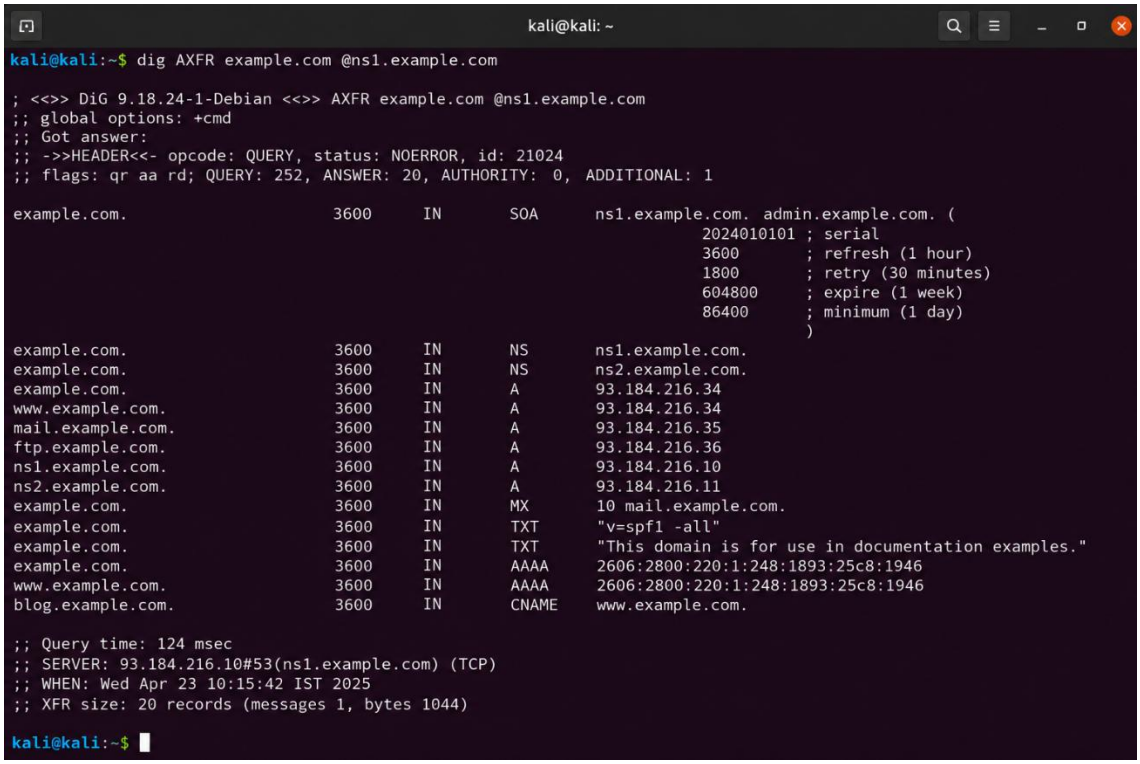
Both names are placeholders. They must be replaced only with the actual domain and authoritative server explicitly included in the authorized assessment scope.

2.6.1 Procedure

1. Identify the authorized domain.
2. Determine the authoritative name servers using public DNS information.
3. Select the authoritative server included in the test scope.
4. Send an AXFR request using dig.
5. Review the response to determine whether the server transfers the zone or refuses the request.
6. Document the result and its security implications.

Command used:

dig AXFR example.com @ns1.example.com



2.6.2 Successful Zone Transfer

If the server returns the zone records and completes the transfer, the result indicates that the requesting client was permitted to obtain the zone.

A successful transfer is not automatically a vulnerability. Some transfers are intentionally permitted for authorized secondary DNS servers.

The finding becomes a security concern when an unauthorized client can obtain zone data that should be restricted.

2.6.3 Failed Zone Transfer

A server may refuse the request or return a response indicating that the operation is not permitted.

This may indicate that the server restricts transfers appropriately, but the analyst should verify the result against the intended configuration and the full scope of the test.

A failed request does not prove that every aspect of DNS configuration is secure.

2.7 Interpretation of DNS Records

If an unauthorized zone transfer succeeds, the analyst should examine the returned records to determine what information has been disclosed.

Record Type	Information Provided	Potential Security Relevance
A	IPv4 address for a hostname	Helps identify the address associated with a system
AAAA	IPv6 address for a hostname	Reveals IPv6 addressing information
MX	Mail server information	Provides context about email infrastructure
NS	Authoritative name servers	Identifies DNS infrastructure
CNAME	Hostname alias	May reveal service relationships
TXT	Text-based DNS data	May reveal domain verification or email security configuration
SOA	Zone administration information	Provides information about the zone's administrative configuration
SRV	Service location information	May reveal the names and ports of certain services

The records should be interpreted in context. Some information, such as public mail server records, is intended to be publicly accessible. The main concern is unnecessary exposure of the complete zone or records that reveal internal infrastructure.

2.8 Security Implications of Successful AXFR

2.8.1 Internal Host Identification

A zone may contain hostnames that suggest the roles of particular systems.

Names associated with databases, administrative tools, development environments, or internal applications may help a security analyst understand the organization's infrastructure.

If such records are exposed to unauthorized clients, attackers may use them to guide additional reconnaissance.

2.8.2 Mail Server Identification

MX records identify the mail servers associated with a domain.

Although these records are often public, they may help an attacker understand the organization's email infrastructure and create more targeted social engineering attempts.

2.8.3 Subdomain Discovery

A full zone transfer may reveal many subdomains in a structured response.

These records may identify web applications, service endpoints, and other hostnames that are not linked from the organization's main website.

The discovery of a hostname does not prove that the corresponding service is reachable or vulnerable. Additional verification is required.

2.8.4 Infrastructure Mapping

DNS records may reveal relationships between hostnames, aliases, and network addresses.

When combined with other public information, this can help an attacker form a more detailed picture of the organization's digital environment.

2.8.5 Targeted Social Engineering

Hostnames and service descriptions may provide context that can be used to create convincing messages.

For example, knowledge of an organization's email or application naming conventions may help an attacker create messages that appear relevant to employees.

2.8.6 Identification of Forgotten Assets

Old DNS records may point to systems that are no longer required or actively maintained.

These records should be reviewed because outdated assets may have different security and ownership arrangements from current production systems.

2.9 Example of Reconnaissance Analysis

Consider a hypothetical zone containing records for a public website, a mail service, and an internal-style application hostname.

A security analyst would not automatically conclude that all the listed systems are vulnerable. Instead, the analyst would document the exposed names, determine whether they should be publicly available, and recommend that the organization verify ownership, purpose, and access controls.

The appropriate response is to restrict unauthorized zone transfers and remove unnecessary records where justified.

This approach distinguishes an information disclosure finding from a confirmed vulnerability in an individual server.

2.10 Security Risks Associated with Misconfiguration

Unauthorized Information Disclosure

The complete zone may be accessible to clients that do not require it.

Increased Reconnaissance Efficiency

An attacker may obtain many records in one operation instead of discovering each hostname separately.

Exposure of Internal Naming Conventions

Hostnames may reveal information about the roles and organization of systems.

Unnecessary Public Information

Obsolete or sensitive records may remain in the zone even when they are no longer required.

Delayed Detection

If DNS logging and monitoring are inadequate, unauthorized transfer attempts may go unnoticed.

These risks are reduced through access restrictions, secure administration, and continuous monitoring.

2.11 Countermeasures for Securing DNS Zone Transfers

2.11.1 Restrict Zone Transfers

Configure the authoritative DNS server to allow transfers only to approved secondary DNS servers.

Unauthorized clients should be denied access to the zone data.

This is the primary control for addressing an unauthorized AXFR finding.

2.11.2 Implement TSIG

Transaction Signature (TSIG) can authenticate DNS messages exchanged between supported systems.

It is commonly used to authenticate authorized zone-transfer communications.

TSIG keys must be stored securely, managed carefully, and rotated according to organizational policy.

2.11.3 Separate Internal and External Zones

Maintain appropriate separation between internal DNS zones and publicly accessible DNS zones.

External zones should contain records required for public services. Internal hostnames should remain in appropriately protected internal DNS infrastructure unless external publication is necessary.

2.11.4 Apply Firewall Controls

Restrict zone-transfer traffic and DNS administration to approved systems and network paths.

Firewall rules should support legitimate DNS operations while preventing unnecessary access.

2.11.5 Remove Obsolete Records

Review DNS zones regularly and remove records that are no longer needed after confirming their status with the responsible system owners.

This reduces unnecessary exposure and helps maintain an accurate asset inventory.

2.11.6 Update DNS Software

Maintain supported DNS server software and apply relevant security updates.

Secure software maintenance reduces the risk associated with known vulnerabilities and improves the reliability of the DNS infrastructure.

2.11.7 Monitor DNS Activity

Enable logging for zone-transfer requests, configuration changes, and other security-relevant events.

Investigate unexpected AXFR attempts and alert on suspicious activity.

2.11.8 Protect Administrative Access

Use strong authentication, restrict administrative permissions, and protect DNS configuration files from unauthorized modification.

Configuration changes should be documented and reviewed.

2.12 Verification After Remediation

After implementing the corrective measures, the security analyst should repeat the authorized test.

The verification process should confirm that:

- Unauthorized clients cannot retrieve the zone.
- Approved secondary servers can still perform legitimate transfers.
- DNS resolution continues to work correctly.
- Monitoring records the relevant requests.
- Obsolete records have been reviewed.
- The remediation is documented.

The purpose is to ensure that security has improved without disrupting legitimate DNS functionality.

2.13 Reporting the Finding

The final penetration-testing report should contain the following details:

Finding title: Unauthorized DNS Zone Transfer

Affected asset: The authoritative DNS server and zone identified within the authorized scope.

Observation: An AXFR request was accepted from a client that was not authorized to receive the zone data.

Evidence: The relevant DNS response, collected securely and with unnecessary sensitive details redacted.

Potential impact: Disclosure of hostnames, mail infrastructure information, and other DNS records that may support reconnaissance.

Recommended remediation: Restrict zone transfers to approved secondary servers, configure appropriate authentication, review internal and external zones, and implement monitoring.

Verification: Repeat the authorized test to confirm that unauthorized transfers are denied.

The report should avoid including sensitive record values unnecessarily, especially when the report is distributed beyond the personnel responsible for remediation.

2.14 Ethical and Legal Considerations

DNS zone-transfer testing must be performed only against systems covered by the authorization.

The analyst should not test unrelated domains or attempt to access infrastructure outside the defined scope.

Any exposed records should be handled securely and disclosed only to authorized personnel.

The objective is to verify the security configuration, minimize unnecessary data collection, and provide evidence that supports remediation.

2.15 Conclusion

DNS zone transfers are an important mechanism for synchronizing DNS information between authoritative servers. However, a misconfigured server may permit unauthorized clients to retrieve a complete zone.

The dig utility can be used during an authorized penetration test to request AXFR and determine whether the server permits the transfer.

If unauthorized access succeeds, the returned records may reveal hostnames, mail server information, subdomains, and other infrastructure details that help attackers perform reconnaissance.

The organization should restrict zone transfers to authorized secondary servers, use TSIG where appropriate, separate internal and external DNS, maintain secure DNS configurations, and monitor suspicious requests.

Finally, the analyst should verify the corrective measures through authorized retesting and document the results in a clear security assessment report.

QUESTION 3: INTRODUCTION TO SOCIAL ENGINEERING – SOCIAL ENGINEERING ATTACKS AND COUNTERMEASURES

3.1 Introduction

Social engineering is a technique in which attackers manipulate human behavior to obtain confidential information, gain unauthorized access, or persuade individuals to perform actions that compromise security.

Rather than relying exclusively on technical vulnerabilities, social engineering exploits trust, urgency, fear, curiosity, authority, and other psychological factors.

Organizations may have firewalls, antivirus software, and secure applications, but employees can still be targeted through deceptive emails, phone calls, messages, or websites.

Phishing is one of the most common forms of social engineering. It involves sending fraudulent communications that appear to come from legitimate sources and encouraging recipients to reveal information or follow unsafe instructions.

In the given scenario, employees receive an email that appears to come from the IT department. The email claims that an urgent security update requires employees to verify their login credentials through a provided link.

This scenario strongly indicates a phishing attack, specifically a credential-harvesting attempt using impersonation and urgency.

Employees should verify the message through trusted channels and avoid clicking the link or entering credentials until its legitimacy has been established.

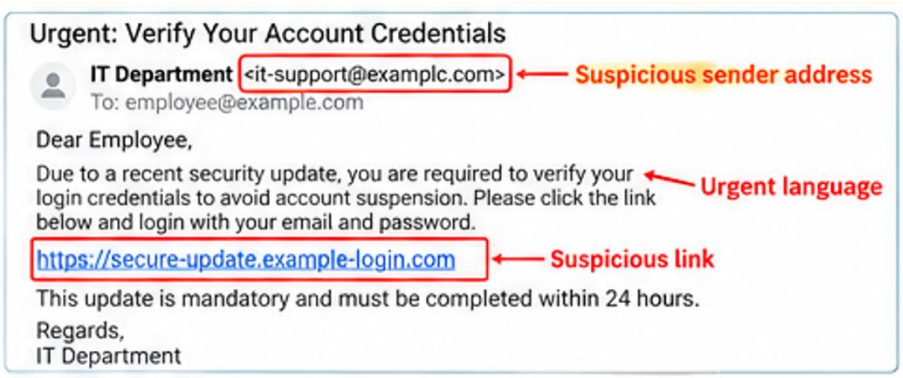


Figure 3.1: Example of a phishing email with warning signs.

3.2 Objectives

The main objectives of this assessment are:

1. To identify the type of social engineering attack described.
2. To explain the psychological techniques used by the attacker.
3. To identify warning signs in the suspicious email.
4. To apply suitable countermeasures before responding.
5. To explain how the countermeasures prevent credential theft.
6. To recommend technical email and authentication controls.
7. To describe appropriate incident reporting and response procedures.

3.3 Identification of the Attack

The attack described in the scenario is **phishing through impersonation of the IT department**.

The attacker sends an email that appears to be a legitimate internal communication and claims that an urgent security update requires credential verification.

The provided link may lead to a fraudulent website designed to collect usernames and passwords.

The attacker may then attempt to misuse the stolen credentials to access email accounts, business applications, or other organizational resources.

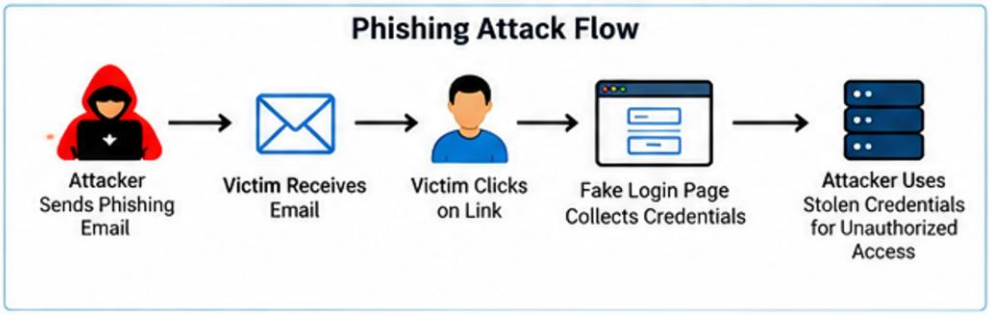


Figure 3.2: Phishing attack flow diagram.

3.3.1 Why This Is Phishing

The scenario contains several characteristics of phishing:

- The message impersonates a trusted department.
- It creates urgency by referring to a security update.
- It asks employees to verify login credentials.
- It provides a link that may lead to a fraudulent login page.
- It attempts to persuade employees to act before verifying the request.

The combination of impersonation, urgency, and credential collection makes phishing the most appropriate classification.

3.3.2 Related Social Engineering Techniques

Pretexting: The attacker creates a false explanation, such as a required security update, to make the request appear legitimate.

Authority impersonation: The attacker pretends to represent the IT department, which employees may trust to manage their accounts.

Urgency manipulation: The message encourages immediate action and discourages careful verification.

Credential harvesting: The linked page may collect authentication information submitted by unsuspecting employees.

These techniques may be used together in a single phishing attempt.

3.4 Psychological Techniques Used by the Attacker

3.4.1 Trust in Authority

Employees commonly depend on the IT department for account security, password resets, software updates, and technical support.

An attacker who impersonates IT support may exploit this trust to increase the likelihood that employees will follow instructions.

3.4.2 Urgency and Fear

The email describes the security update as urgent. Employees may fear that their accounts will be disabled or that they will violate company policy if they do not respond quickly.

This pressure can reduce careful decision-making.

3.4.3 Familiarity

An email that uses organizational language or familiar terminology may appear credible even when the sender is fraudulent.

Employees may incorrectly assume that a message is legitimate because it resembles previous IT communications.

3.4.4 Fear of Negative Consequences

A message that threatens account suspension, restricted access, or security consequences may persuade employees to follow instructions without independent verification.

3.4.5 Curiosity and Compliance

Some employees may follow the link simply to determine what the update requires.

The attacker takes advantage of this behavior by directing users toward a page that may collect sensitive information.

3.5 Warning Signs in the Email

Employees should review the message carefully before responding.

Warning Sign	Explanation	Recommended Action

Unexpected request for credentials	Legitimate services generally should not ask users to re-enter credentials through an unsolicited email link	Do not enter credentials; verify independently
Urgent language	The message pressures the employee to act quickly	Pause and check the request
Suspicious sender address	The sender may use a lookalike or unrelated domain	Verify the complete address
Unfamiliar URL	The link may point to a fraudulent website	Do not click; use a trusted route to the service
Unusual grammar or formatting	The message may contain inconsistencies	Treat as a warning sign, not definitive proof
Unexpected attachment	The file may contain harmful content	Do not open until verified
Requests to bypass procedures	The message may discourage normal verification	Follow organizational policy

No single warning sign proves that an email is malicious. Employees should evaluate the complete context and verify suspicious requests through trusted channels.

3.6 Countermeasures Employees Should Follow

3.6.1 Do Not Click the Link Immediately

Employees should avoid clicking links in unexpected emails requesting authentication or urgent account verification.

Instead, they should navigate to the organization's known official website or use a trusted application already provided by the organization.

This reduces the risk of being redirected to a fraudulent login page.

3.6.2 Verify the Sender's Identity

Employees should inspect the full sender address and compare the domain with the organization's legitimate domain.

A display name such as "IT Support" is not sufficient evidence that the message is authentic.

If the request is unexpected, employees should confirm it through a trusted communication channel rather than replying directly to the suspicious message.

3.6.3 Inspect the Link Destination Safely

Employees should check the destination of the link without opening it.

They should look for misspelled domain names, unexpected subdomains, misleading URL structures, and domains unrelated to the organization.

However, a professional-looking URL does not guarantee safety, and suspicious links should not be opened simply to investigate them.

3.6.4 Confirm the Security Update Independently

If the message claims that a security update is required, employees should check the organization's approved IT announcements, official service portal, or established internal communication channel.

They should contact IT support using a known phone number, help-desk portal, or verified internal contact.

They should not rely solely on contact details included in the suspicious email.

3.6.5 Never Enter Credentials on an Unverified Page

Employees should not enter passwords, one-time codes, recovery codes, or other authentication information into a page reached through an unexpected message.

They should access the service through a trusted route and follow the organization's established authentication process.

This action directly reduces the risk of credential harvesting.

3.6.6 Report the Email

Employees should report the suspicious message using the organization's report-phishing button or designated security email address.

They should include the original message when required by the reporting procedure and avoid forwarding it casually to other employees.

Prompt reporting enables the security team to investigate and protect other users.

3.6.7 Avoid Opening Unexpected Attachments

If the message includes an attachment, employees should not open it until its legitimacy has been confirmed.

An unexpected file may contain malware or direct the user to a fraudulent website.

3.6.8 Follow Organizational Policies

Employees should follow approved procedures for account verification, software updates, and password resets.

A request to bypass normal security procedures should be treated as suspicious.

3.7 How These Actions Prevent Credential Theft

The recommended actions reduce the attacker's opportunity to collect and misuse authentication information.

Avoiding the link prevents the employee from being redirected to a potentially fraudulent login page.

Verifying the sender helps identify impersonation and suspicious domains.

Using an official website or application reduces dependence on links supplied by an unverified message.

Confirming the request independently prevents an attacker from controlling both the suspicious message and the verification process.

Refusing to enter credentials on an unverified page directly prevents the employee from voluntarily submitting authentication information to a suspected credential-harvesting site.

Reporting the email allows security personnel to block malicious messages and warn other employees.

Using MFA provides an additional authentication barrier if a password is stolen. Phishing-resistant MFA is particularly valuable because it can protect against some attacks that bypass or manipulate weaker authentication methods.

Together, these actions reduce the likelihood of successful credential theft.

3.8 Technical Countermeasures for the Organization

Employee behavior should be supported by technical security controls.

3.8.1 Email Filtering

Organizations should deploy email security controls that detect suspicious messages, malicious links, impersonation attempts, and dangerous attachments.

Filtering reduces the number of phishing emails that reach employee inboxes.

3.8.2 SPF – Sender Policy Framework

SPF allows a domain owner to specify which mail servers are authorized to send email for that domain.

Receiving systems can use SPF results when evaluating the authenticity of messages.

SPF helps reduce certain forms of domain spoofing, but it does not prevent all phishing attacks.

3.8.3 DKIM – DomainKeys Identified Mail

DKIM uses a cryptographic signature to help verify that signed portions of a message have not been altered and that the message is associated with a signing domain.

It is one component of an effective email authentication strategy.

3.8.4 DMARC – Domain-based Message Authentication, Reporting and Conformance

DMARC builds on SPF and DKIM alignment and allows domain owners to publish policies for messages that fail authentication checks.

It also supports reporting that helps organizations identify potential misuse of their domains.

3.8.5 Multi-Factor Authentication

MFA requires an additional authentication factor beyond the password.

If an attacker obtains a password, MFA can reduce the likelihood of unauthorized access. Phishing-resistant methods, such as FIDO2 security keys and passkeys, should be preferred where supported.

MFA should not be treated as a replacement for email verification and employee awareness.

3.8.6 Conditional Access and Login Monitoring

Organizations can monitor authentication attempts for unusual locations, unfamiliar devices, suspicious sign-in patterns, and other risk indicators.

Conditional access policies can require additional verification or block access when the risk is sufficiently high.

3.8.7 Endpoint Security

Endpoint protection tools can identify suspicious files, malware activity, and unusual process behavior.

These tools help limit the consequences if an employee interacts with a malicious attachment or website.

3.8.8 Browser and URL Protection

Organizations may use secure web gateways, DNS filtering, browser protection, and URL reputation checks to prevent users from visiting known malicious destinations.

These controls complement employee awareness and email filtering.

3.9 Organizational Policies for Preventing Phishing

3.9.1 Email Security Policy

The organization should define how employees must handle suspicious emails, links, attachments, and requests for confidential information.

3.9.2 Credential Management Policy

Employees should use unique passwords, approved password managers where available, and MFA for important systems.

Credentials should never be shared through email or entered into unverified pages.

3.9.3 IT Communication Policy

The organization should establish clear procedures for communicating genuine security updates, password resets, and account-related notices.

Employees should know how to verify whether an IT message is legitimate.

3.9.4 Incident Reporting Policy

The policy should explain how employees can report suspected phishing, accidental credential disclosure, or suspicious file activity.

Reporting procedures should be easy to follow and available to all employees.

3.9.5 Security Awareness Policy

All employees should receive cybersecurity awareness training during onboarding and at regular intervals.

Training should include phishing recognition, credential protection, safe attachment handling, and reporting procedures.

3.9.6 Access Control Policy

Employees should receive only the permissions required for their responsibilities.

Least-privilege access reduces the potential impact if an account is compromised.

3.10 Employee Awareness Training

A structured awareness program can help employees recognize social engineering attacks.

Training Topics

- Common phishing techniques.
- Sender address verification.
- Safe handling of suspicious links.

- Identification of fake login pages.
- Password protection and MFA.
- Recognition of suspicious attachments.
- Independent verification of urgent requests.
- Reporting and responding to security incidents.

Simulated Phishing Exercises

Organizations can conduct authorized phishing simulations to measure employee responses.

The results can help identify common mistakes and determine where additional training is required.

Simulations should be used to improve awareness and security behavior rather than simply punish employees.

Measuring Training Effectiveness

The organization can monitor:

- Phishing link-click rates.
- Credential-submission rates in authorized simulations.
- Suspicious email reporting rates.
- Time taken to report suspicious messages.
- Repeat interaction rates across campaigns.

Consistent measurement helps the organization determine whether its awareness program is improving.

3.11 Incident Response if an Employee Has Already Clicked

If an employee has already clicked the link, the appropriate response depends on what happened next.

Case 1: The Employee Clicked but Did Not Enter Information

The employee should report the incident to IT or the security team. The team should review the URL and relevant security logs and determine whether further action is needed.

Case 2: The Employee Entered Credentials

The employee should immediately contact IT or the security team through a trusted channel.

The response team should reset the affected password, revoke active sessions where appropriate, review suspicious sign-ins, and investigate whether the account was accessed without authorization.

If the password was reused elsewhere, those accounts should also be assessed and protected.

Case 3: The Employee Entered an MFA Code

The incident should be reported immediately because the attacker may have used the code during an attempted login.

The security team should revoke sessions, review authentication logs, reset or re-establish affected authentication methods as appropriate, and investigate suspicious account activity.

Case 4: The Employee Downloaded or Opened a File

The employee should follow the organization's incident reporting procedure and avoid further interaction with the file.

The security team may isolate the device, examine endpoint alerts, scan for malware, and determine whether the file executed or caused unauthorized activity.

Case 5: The Employee Approved an Unexpected Authentication Request

The employee should report the event immediately. The security team should revoke affected sessions, investigate account activity, and review the authentication configuration.

3.12 Incident Response Steps

A formal response process should include the following stages.

Identification: Determine the affected employees, accounts, devices, and messages.

Containment: Block malicious URLs, restrict compromised accounts, and isolate affected endpoints when necessary.

Credential protection: Reset exposed credentials, revoke active sessions, and review authentication methods.

Investigation: Examine email records, sign-in logs, endpoint events, and suspicious network activity.

Eradication: Remove malicious files or unauthorized access and correct the identified weakness.

Recovery: Restore affected services and verify that security controls are functioning properly.

Lessons learned: Document the incident, improve detection mechanisms, and provide additional training where appropriate.

3.13 Example of a Safe Employee Response

If an employee receives an email stating that an urgent security update requires login verification, the employee should not click the supplied link or enter credentials.

Instead, the employee should:

1. Check the sender's full email address.
2. Treat the urgency and credential request as warning signs.
3. Access the organization's official portal through a trusted route.
4. Confirm the update with the IT department through a known communication channel.
5. Report the suspicious message to the security team.
6. Follow the official instructions only after the request is verified.

This procedure reduces reliance on the sender's claims and prevents the employee from handing credentials to an unverified destination.

3.14 Importance of a Security-Aware Culture

Cybersecurity is a shared responsibility between employees, IT administrators, and management.

Employees should be encouraged to question unusual requests, verify identities, and report suspicious activity.

Management should provide clear procedures, practical training, and effective technical tools. Security teams should respond promptly to reports and communicate lessons learned.

A positive security culture reduces the likelihood that employees will ignore warning signs or hide mistakes that need immediate investigation.

3.15 Recommended Action Plan

Priority	Recommended Action	Expected Benefit
Immediate	Warn employees about the suspicious email and provide a reporting channel	Reduces further interaction
Immediate	Investigate any submitted credentials or opened files	Helps identify possible compromise
Short term	Review email filtering and sender authentication	Improves phishing detection
Short term	Enforce MFA and secure account recovery	Reduces the risk of unauthorized access
Medium term	Conduct phishing awareness training	Improves recognition and reporting

Medium term	Establish formal incident response procedures	Improves containment and recovery
Ongoing	Conduct authorized simulations and review metrics	Supports continuous improvement

3.16 Conclusion

The scenario describes a phishing attack in which an attacker impersonates the IT department and uses urgency to persuade employees to verify their credentials through a link.

The attack exploits trust in authority, fear of security consequences, and the tendency to act quickly under pressure.

Employees should avoid clicking unexpected links, verify sender identities, confirm security updates through trusted channels, never enter credentials on unverified pages, and report suspicious messages immediately.

Organizations should support these actions through email filtering, SPF, DKIM, DMARC, multi-factor authentication, secure endpoint controls, clear IT communication procedures, and regular awareness training.

If credentials have already been submitted, the affected employee should contact IT immediately so that passwords and sessions can be secured and suspicious activity investigated.

By combining employee awareness with technical controls and a clear incident response process, the organization can reduce the risk of credential theft and strengthen its overall cybersecurity posture.

OVERALL CONCLUSION

This assessment demonstrates the application of footprinting, DNS security testing, and social engineering awareness to identify and reduce cybersecurity risks.

Question 1 examined passive footprinting tools that can help identify domain registration information, publicly available email addresses, website technologies, and exposed subdomains. Tools such as WHOIS, ICANN Lookup, Hunter.io, Wappalyzer, BuiltWith, certificate transparency services, and passive DNS sources can help build an understanding of an organization's public digital footprint.

Question 2 examined DNS zone transfers and the use of dig to test whether an authorized DNS server permits AXFR requests. Unauthorized transfers may disclose DNS records that support reconnaissance. Restricting transfers, using appropriate authentication, separating internal and external zones, and monitoring DNS activity help reduce this risk.

Question 3 examined a phishing scenario in which an attacker impersonates the IT department and requests credentials through an urgent security-update email. Employee verification, safe link handling, phishing reporting, multi-factor authentication, email security controls, and incident response procedures help prevent credential theft.

Together, these scenarios show that effective cybersecurity requires technical knowledge, careful analysis, appropriate decision-making, and ethical conduct. Security professionals should gather only necessary information, verify their findings, document risks clearly, and recommend practical controls.

All footprinting and testing activities should be conducted within an authorized scope. Organizations that maintain accurate asset inventories, secure DNS infrastructure, educate employees, and continuously review their security controls can reduce exposure and improve resilience against cyberattacks.

CODE OF CONDUCT

I K. Sri Lasya (192472216) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment.

I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the Student: K. Sri Lasya